SSH

Rapport d'activité

Sitka

PARIS PANTHÉON-ASSAS UNIVERSITÉ

2023-2024

1.1 Présentation de l’entreprise

Sitka, pionnière dans le domaine de la pêche, vise à introduire des avancées significatives dans le secteur maritime. Avec une croissance rapide, l'entreprise reconnaît le besoin urgent de solidifier son infrastructure IT pour assurer à la fois la sécurité et l'efficience de ses opérations.

1.2 Contexte et besoin

Actuellement, Sitka utilise diverses méthodes d'authentification pour gérer ses ressources informatiques, ce qui entraîne des difficultés dans la gestion des utilisateurs et des appareils. Ces défis compromettent l'accès rapide aux ressources nécessaires et exposent l'entreprise à des risques en matière de sécurité. Pour rationaliser la gestion des utilisateurs, renforcer la sécurité et faciliter l'accès aux ressources, Sitka envisage de mettre en place SSH (Secure Shell), une solution réputée pour ses capacités sécurisées de connexion à distance.

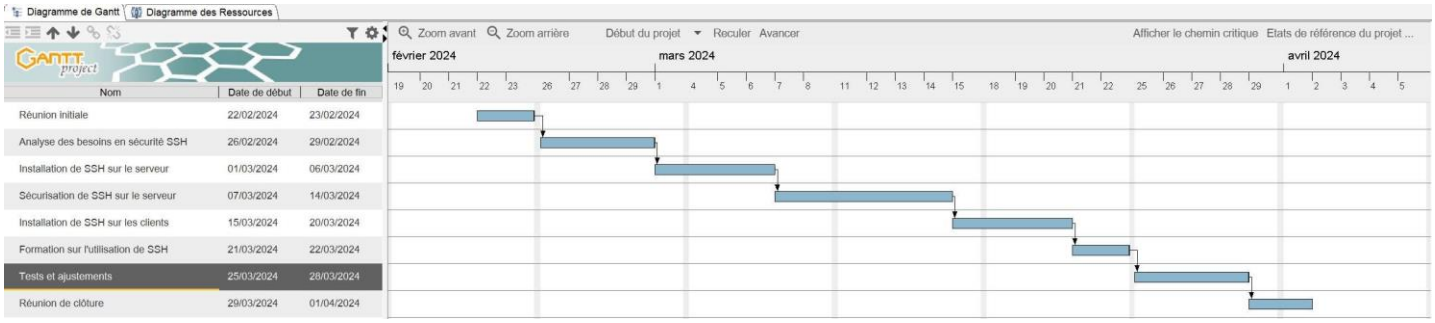
1.3 Cahier des charges

- **Mise en place de l’infrastructure réseau pour prendre en charge SSH.**
- **Création d’une identité numérique pour les connexions SSH des comptes utilisateurs** en générant une paire de clés (privée et publique), avec gestion de la passphrase et de l'agent SSH.
- **Configuration du fichier sshd_config** pour définir les paramètres de sécurité et les autorisations appropriées.
- **Création d’une bannière SSH** pour communiquer des messages d'information ou d'avertissement.
- **Test de la connexion SSH avec une solution mobile smartphone.**
- **Implémentation de la double authentification Google** pour renforcer la sécurité des connexions SSH.

Diagramme de Swott

Forces	Faiblesses
• **Sécurité :** SSH assure une communication chiffrée entre deux systèmes sur un réseau non sécurisé, améliorant ainsi la sécurité. • **Authentification :** Il propose diverses méthodes d'authentification, telles que le mot de passe, la clé publique et l'authentification Kerberos, garantissant un accès sécurisé. • **Polyvalence :** SSH peut être utilisé à diverses fins telles que l'exécution de commandes à distance, le transfert de fichiers et le tunneling. • **Indépendance de la plateforme :** SSH est disponible sur plusieurs plateformes, dont Unix, Linux, Windows et macOS, le rendant largement accessible. • **Open Source :** De nombreuses implémentations de SSH sont open source, permettant un examen et des contributions de la communauté.	• **Configuration complexe :** La configuration de SSH pour une sécurité optimale peut être complexe, surtout pour les utilisateurs peu familiers avec les concepts cryptographiques. • **Gestion des clés :** La gestion des clés SSH sur plusieurs systèmes et utilisateurs peut être difficile et sujette aux erreurs. • **Surcharge de performance :** Le chiffrement et le déchiffrement des données peuvent entraîner une surcharge, impactant potentiellement les performances, notamment sur des réseaux à latence élevée. • **Vulnérabilités :** Comme tout logiciel, les implémentations de SSH sont susceptibles de présenter des vulnérabilités et nécessitent des mises à jour régulières pour rester sécurisées. • **Point de défaillance unique :** Si les clés SSH sont compromises, cela peut conduire à un accès non autorisé aux systèmes sensibles, mettant en évidence un point de défaillance unique.
Opportunités	**Menaces**
• **Intégration avec DevOps :** SSH peut être intégré aux flux de travail DevOps pour une automatisation sécurisée et une gestion de la configuration. • **Normes de sécurité améliorées :** Les développements continus dans les normes et protocoles cryptographiques peuvent entraîner des améliorations dans la sécurité SSH. • **Adoption du cloud :** Avec l'adoption croissante de l'informatique en nuage, il existe un besoin croissant de solutions d'accès distant sécurisées telles que SSH. • **Outils conviviaux :** Le développement d'outils de gestion SSH conviviaux peut simplifier la gestion des clés et les tâches de configuration.	• Menaces cybernétiques avancées : Les menaces de cyberattaques évolutives représentent un risque pour la sécurité de SSH, y compris les attaques ciblant les méthodes d'authentification faibles et les vulnérabilités cryptographiques. • Exigences de conformité : Les normes de conformité strictes peuvent imposer des exigences supplémentaires sur les configurations SSH, augmentant la complexité et les coûts. • Menaces internes : Les menaces internes, telles que l'accès non autorisé par les employés ou les contractuels, peuvent compromettre la sécurité SSH si des contrôles d'accès appropriés ne sont pas en place. • Émergence d'alternatives : L'émergence de protocoles de communication sécurisés alternatifs peut diminuer la pertinence de SSH.

Diagramme de Gantt



Sommaire

- Mise en place de l'infrastructure réseaux..... p.4

- Création d'une identité numérique pour les connexions en ssh de comptes utilisateurs en créant une paires de clés (privé et publique) …….....….....….p.7

- Passphrase et agent ssh…….....……p.7

- Configuration du fichier sshd config…….....……p.8

- Création d'une bannière ssh…….....……..p.9

- Test de la connexion ssh avec une solution mobile (smartphone)…….....……...…p.10

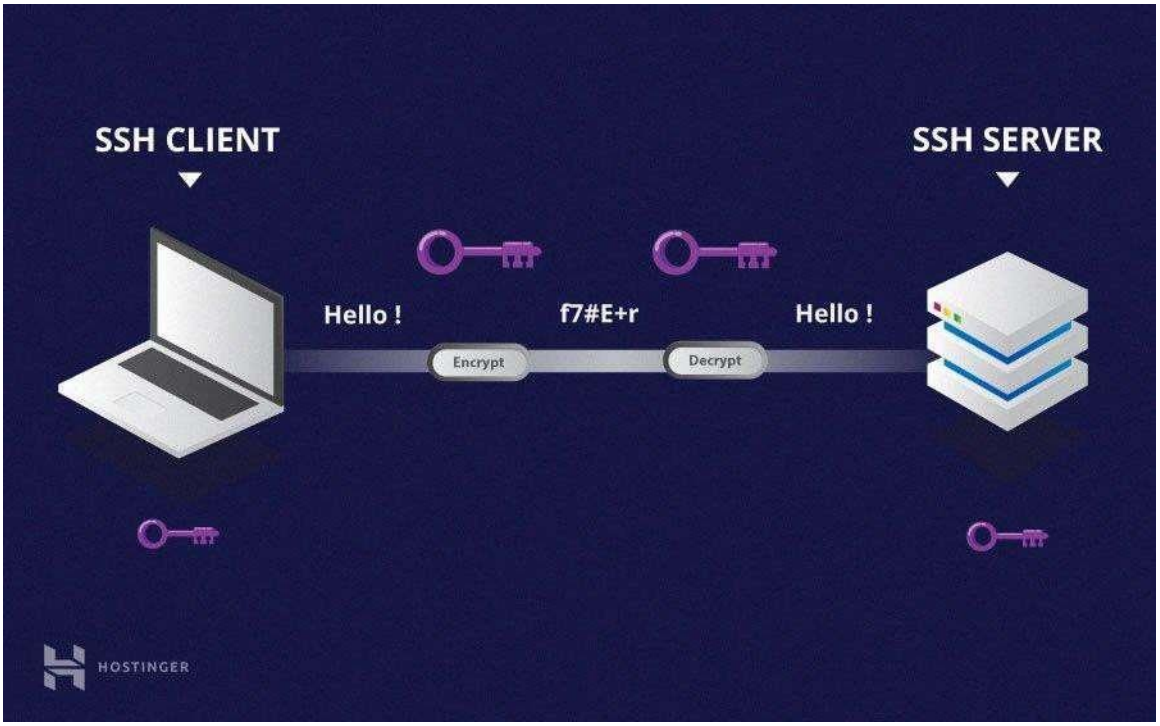
- La double authentification google…….....…..……..p.10

- Activer le client SSH intégré à Windows…….....……p.12

Introduction

OpenSSH

OpenSSH est un ensemble d'outils informatiques libres permettant des communications sécurisées sur un réseau informatique en utilisant le protocoleSSH.



LVM Crypté

Lorsqu'une partition LVM cryptée est utilisée, la clé de cryptage est stockéedans la mémoire (RAM). … Si cette partition n'est pas cryptée, le voleur peutaccéder à la clé et l'utiliser pour décrypter les données des partitions cryptées. C'est pourquoi, lorsque vous utilisez des partitions chiffrées LVM, il est recommandé de chiffrer également la partition d'échange.

Diminuer les surfaces d'attaques sur nos serveurs et clients SSH :

Nous allons sécuriser le **disque dur** et les **menus de démarrage** sur les machines virtuels :Mise en place de l'infrastructure

- Installer les machines virtuelles : 2 Serveurs sous Linux Debian 11, Windows 10, et Smartphone,
- Installation LVM chiffré (Disque dur).

Installation du serveur Debian 11 sous Linux

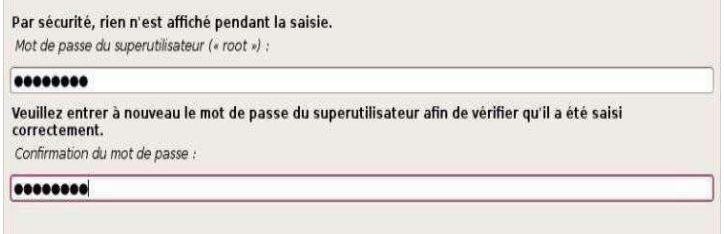
Choisir le pays d'emplacement « France »

Choisir la langue du paquet installer en français

Configurer la langue du clavier en français

Les options sont en cours d'installation

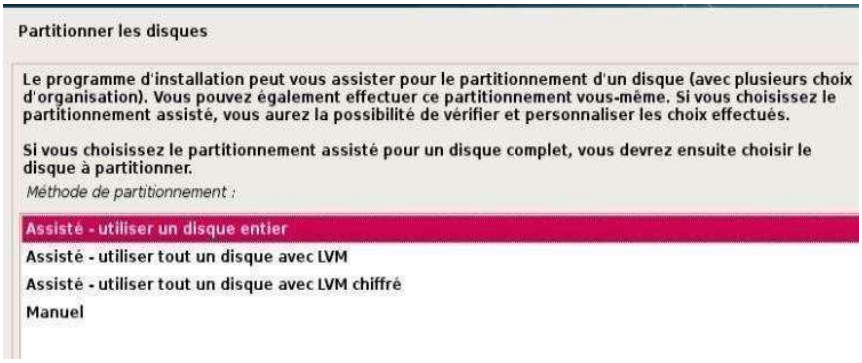
Définir le mot de passe administrateur (root)



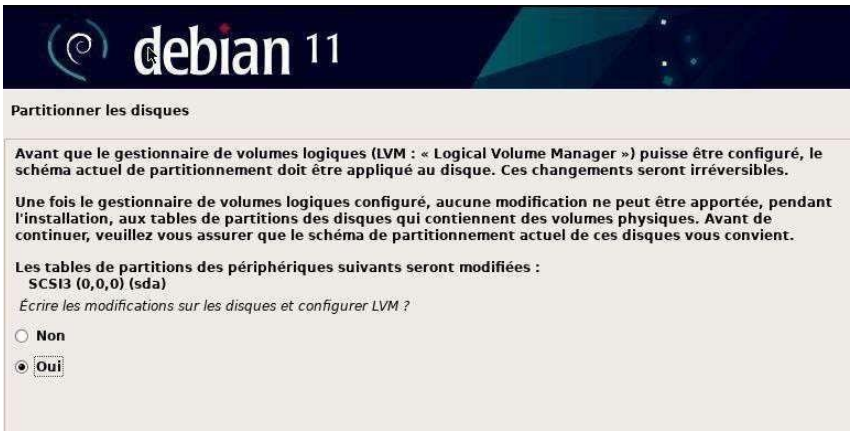
Crée un utilisateur

Entrez le nom del'utilisateurkaiser
Définir puis confirmer le mot de passe

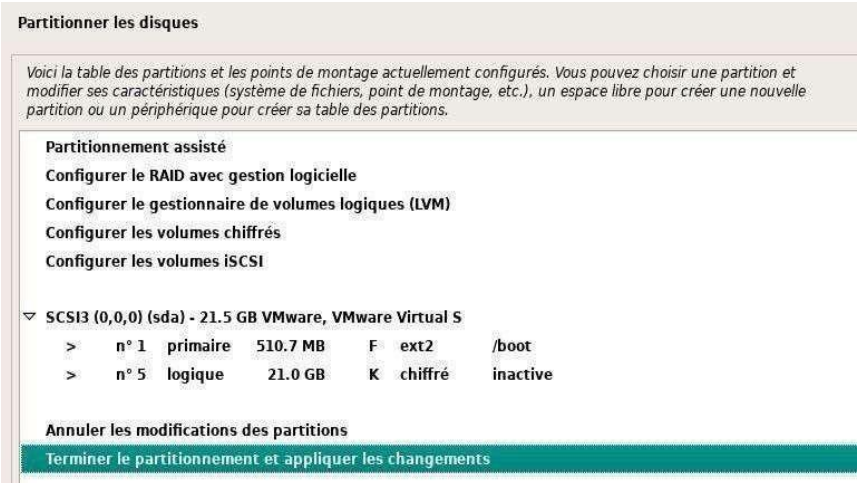
Lancement du partionnement de disque : :utiliser **le disque en LVM** Chiffré



Appliquer les modifications au disque

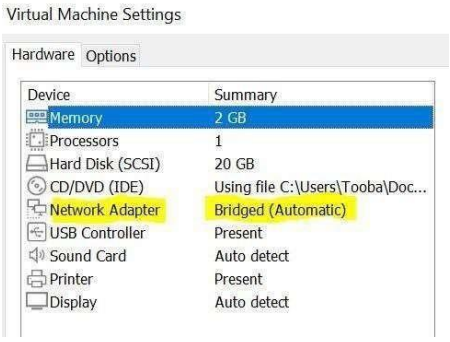


Les partitions primaires et logiques ont été créé sur le disque



Configuration du serveur Debian 11 sous linux

Configuration de la carte réseau du serveur ssh 1 de même pour Windows 10



Définir le nom du serveur

```
root@debian:~# hostnamectl set-hostname sshserver1
```

Mise à jour du serveur

```
root@debian:~# apt update && apt upgrade
Ign :1 cdrom://[Debian GNU/Linux 11.2.0 _Bullseye_ - Official
Err :2 cdrom://[Debian GNU/Linux 11.2.0 _Bullseye_ - Official
  Veuillez utiliser apt-cdrom afin de faire reconnaître ce céd
déroms
Réception de :3 http://deb.debian.org/debian bullseye InReleas
Réception de :4 http://security.debian.org/debian-security bul
Réception de :5 http://deb.debian.org/debian bullseye-updates
```

Installer le paquet openssh-server sur le serveur ssh 1

```
root@sshserver1:~# apt install openssh-server
```

Crée l'utilisateur kaiser puis définir son mot de passe

```
root@sshserver1:~# adduser kaiser
```

Création d'une identité numérique de l'utilisateur kaiser

Se rendre dans le dossier .ssh del'utilisateur kaiser

```
root@sshserver1:~# cd /home/kaiser
root@sshserver1:/home/kaiser# mkdir .ssh
root@sshserver1:/home/kaiser# cd /home/kaiser/.ssh
```

Définir le nom et le mot de passe de la paire de clés privée et publique ainsi que le Passphrase

```
root@sshserver1:/home/kaiser/.ssh# ssh-keygen -t rsa -b 1024
Generating public/private rsa key pair.
Enter file in which to save the key (/root/.ssh/id_rsa): kaiser_rsa
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in kaiser_rsa
Your public key has been saved in kaiser_rsa.pub
The key fingerprint is:
SHA256:j8ZTh3nVXGeWqd84H4q7AugRGStmY2iZrUDMN2otFKI root@sshserver1
The key's randomart image is:
+---[RSA 1024]----+
|+..              B|
|o= o .          Bo|
|E O . +        o o|
|.O O +      o o   |
|+ * o o S + o ...|
| .   o o + o  oo.|
|    . . * . . .o.|
|     . . o . .  .|
|          .oo    |
+----[SHA256]-----+
```

Configuration du fichier SSHD_CONFIG

Afin d'éviter les attaques de force brute on change le port ssh par défaut

```
root@sshserver1:~# nano /etc/ssh/sshd_config
```

Sur sshserver 1 on change le port 22 en 33

```
Include /etc/ssh/sshd_config.d/*.conf

Port 33
#AddressFamily any
#ListenAddress 0.0.0.0
#ListenAddress ::

#HostKey /etc/ssh/ssh_host_rsa_key
#HostKey /etc/ssh/ssh_host_ecdsa_key
#HostKey /etc/ssh/ssh_host_ed25519_key

# Ciphers and keying
#RekeyLimit default none

# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:
allowusers kaiser
LoginGraceTime 1m
PermitRootLogin yes
#StrictModes yes
```

Ctrl + x : enregistrer le fichier sshd_config > oui

Redémarrer le service sshd : service sshd restart

```
root@sshserver1:~# exit
déconnexion
Connection to 192.168.64.65 closed.
PS C:\Users\Tooba> ssh kaiser@192.168.64.65
ssh: connect to host 192.168.64.65 port 22: Connection refused
PS C:\Users\Tooba> ssh kaiser@192.168.64.65 -p 33
kaiser@192.168.64.65's password:
Linux sshserver1 5.10.0-13-amd64 #1 SMP Debian 5.10.106-1 (2022-03-17) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Thu Apr 21 06:19:27 2022 from 192.168.64.108
kaiser@sshserver1:~$
```

Activation de la clé del'agent ssh: : Se connecter avec l'utilisateur root

```
root@sshserver1:/home/kaiser/.ssh# exec ssh-agent bash
root@sshserver1:/home/kaiser/.ssh# ls
kaiser_rsa  kaiser_rsa.pub
root@sshserver1:/home/kaiser/.ssh# ssh-add kaiser_rsa
Enter passphrase for kaiser_rsa:
Identity added: kaiser_rsa (root@sshserver1)
```

Création de la bannière

Installer le programme figlet pour crée une bannière de connexion SSH

```
root@sshserver1:~# apt install figlet
```

Le fichier de la bannière à bien été crée dans le dossier .ssh de l'utilisateur kaiser

```
root@sshserver1:~# figlet Bienvenu, Connexion SSH Kaiser > /home/kaiser/.ssh/banner
```

nano /etc/ssh/sshd_config : Il faut aller chercher le fichier de configuration ssh
déclarer le chemin de la bannière enregistrer les modifications (ctrl+x) >>oui

```
# no default banner path
Banner /home/kaiser/.ssh/banner
```

Après redémarrer le service ssh :**service ssh restart**

Vérification du contenu de la bannière

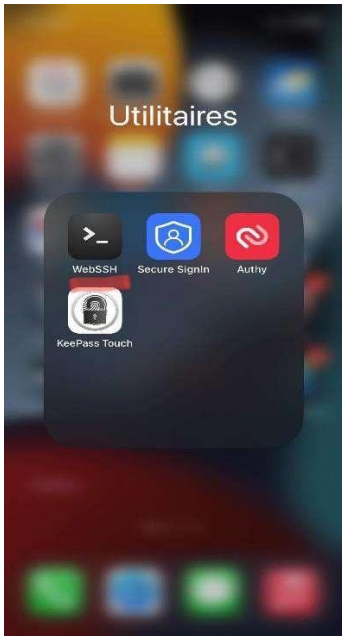
```
kaiser@sshserver1:~$ su
Mot de passe :
root@sshserver1:/home/kaiser# cd .ssh
root@sshserver1:/home/kaiser/.ssh# cat banner
 ____  _
| __ )(_) ___ _ ____   _____ _ __  _   _
|  _ \| |/ _ \ '_ \ \ / / _ \ '_ \| | | |
| |_) | |  __/ | | \ V /  __/ | | | |_| |_
|____/|_|\___|_| |_|\_/ \___|_| |_|\__,_( )
                                        |/
  ____                            _              ____ ____  _   _
 / ___|___  _ __  _ __   _____  _(_) ___  _ __   / ___/ ___|| | | |
| |   / _ \| '_ \| '_ \ / _ \ \/ / |/ _ \| '_ \  \___ \___ \| |_| |
| |__| (_) | | | | | | |  __/>  <| | (_) | | | |  ___) |__) |  _  |
 \____\___/|_| |_|_| |_|\___/_/\_\_|\___/|_| |_| |____/____/|_| |_|

 _  __     _
| |/ /__ _(_)___  ___ _ __
| ' // _` | / __|/ _ \ '__|
| . \ (_| | \__ \  __/ |
|_|\_\__,_|_|___/\___|_|
```

Connexion avec une solution mobile

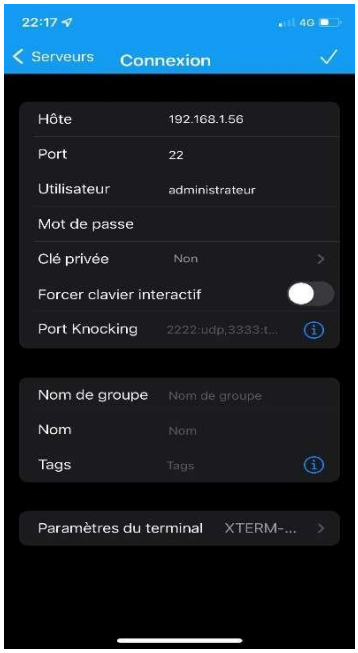
Sur le serveurssh1 avec l'utilisateurkaiser

Vérification del'empruntnumérique > enter le mot de passe > connexion réussie

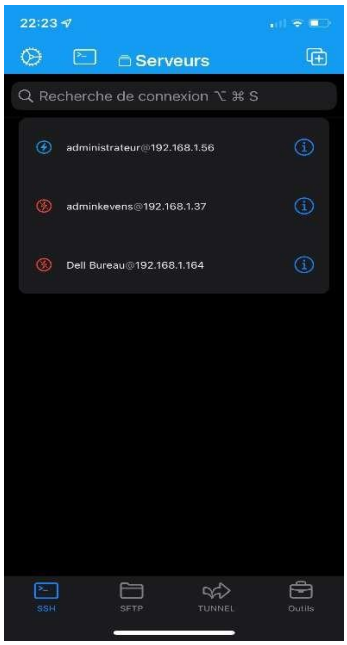
Sur mon téléphone



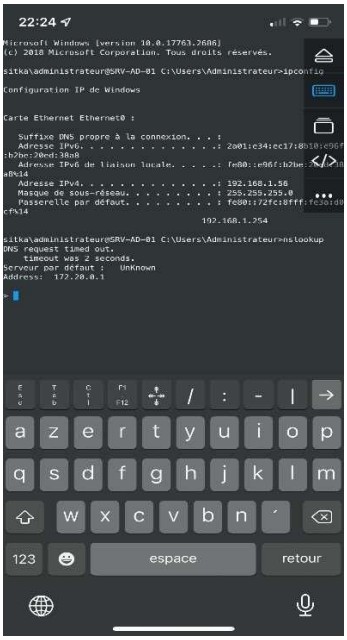
Télécharger apk WebSSH



Entrez l'adresse IP et le port du serveur
Avec le nom et le mot utilisateur.



Le serveur SSH apparaitre.



Voilà ! vous êtes connectée sur votre serveur SSH.

Double authentification google

Installation du google authentificateur :

apt install libpam-google-authenticator

Se rendre pour modifier le fichier sshd de la double authentification

nano /etc/pam.d/sshd

Ajouter 2 lignes à la fin du fichier

```
# authentification google
auth required pam_google_authenticator.so
```

Ctrl X + yes

Rédemarre le service : **service sshd restart** ou **systemctl restart sshd**

Généré le QRCODE de la double authentification google

```
root@sshserver1:~# google-authenticator
```

```
Do you want authentication tokens to be time-based (y/n) y
Warning: pasting the following URL into your browser exposes the OTP secret to Google:
  https://www.google.com/chart?chs=200x200&chld=M|0&cht=qr&chl=otpauth://totp/root@sshserver1%3Fsecret%3D4RCOU5A2IB37J6BWCBZRC5SEFA%26issuer%3Dsshserver1
```

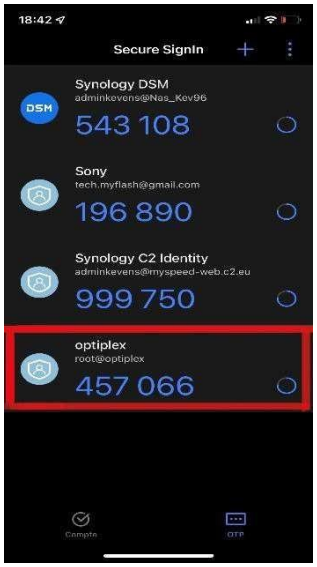
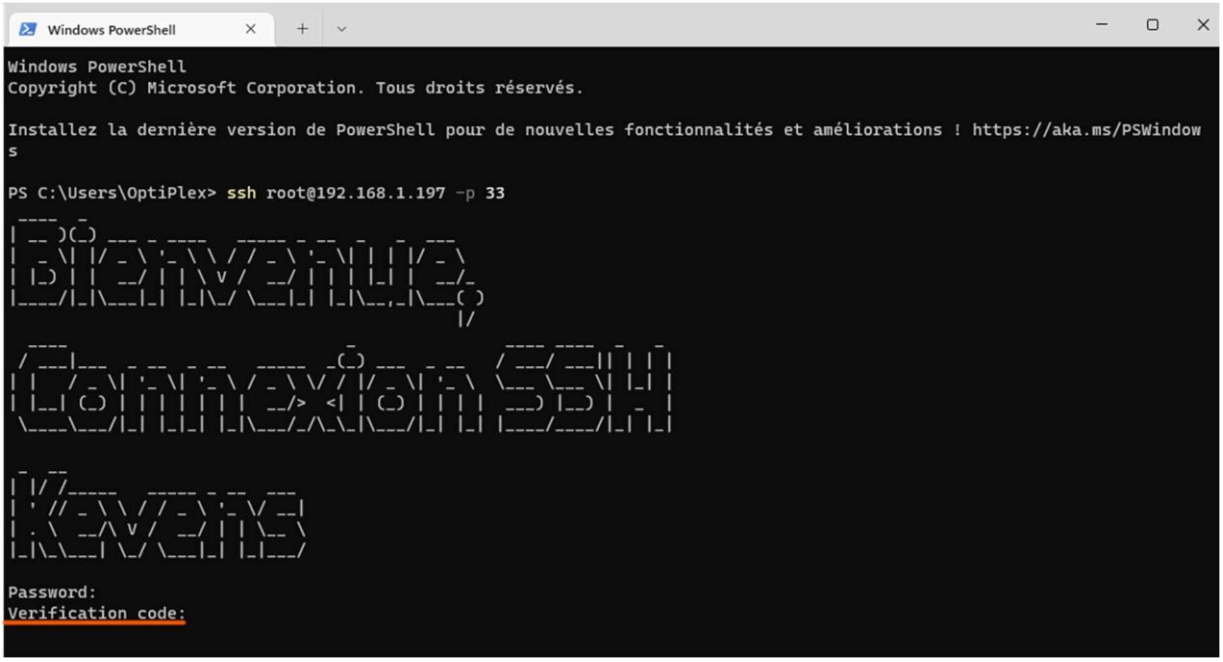
```
Your new secret key is: 4RCOU5A2IB37J6BWCBZRC5SEFA
Enter code from app (-1 to skip): 918038
```

Questions de renforcement de la sécurité authentifiée

```
Your new secret key is: 4RCOU5A2IB37J6BWCBZRC5SEFA
Enter code from app (-1 to skip): 918038
Code confirmed
Your emergency scratch codes are:
  43263684
  38579593
  98493906
  92047573
  28480205

Do you want me to update your "/root/.google_authenticator" file? (y/n) Y

Do you want to disallow multiple uses of the same authentication
token? This restricts you to one login about every 30s, but it increases
your chances to notice or even prevent man-in-the-middle attacks (y/n) Y

By default, a new token is generated every 30 seconds by the mobile app.
In order to compensate for possible time-skew between the client and the server,
we allow an extra token before and after the current time. This allows for a
time skew of up to 30 seconds between authentication server and client. If you
experience problems with poor time synchronization, you can increase the window
from its default size of 3 permitted codes (one previous code, the current
code, the next code) to 17 permitted codes (the 8 previous codes, the current
code, and the 8 next codes). This will permit for a time skew of up to 4 minutes
between client and server.
Do you want to do so? (y/n) Y

If the computer that you are logging into isn't hardened against brute-force
login attempts, you can enable rate-limiting for the authentication module.
By default, this limits attackers to no more than 3 login attempts every 30s.
Do you want to enable rate-limiting? (y/n) Y
```

Test de la double authentification en root.

Dans un premier temps il faut installer **Secure Signin** sur votre téléphone.



Et puis se connecter sur le serveur SSH en root, entrez le mot de passe root. Il va vous demander de vérification code de double authentification sur ton téléphone vous prenez le code à 6 chiffres.